Descrierea problemei

Descrierea plastică

Tot mai multe aplicații folosesc LLM-uri prin chatbots, pipeline-uri RAG și agenți. Aceste integrări aduc noi tipuri de vulnerabilități (ex. prompt injection, system prompt leakage, excessive priviledges, etc), pe care instrumentele normale de analiză nu le pot detecta. Chiar dacă OWASAP Top 10 for LLM conține aceste riscuri, verificarea codului a rămas în mare parte un proces manual, care durează destul de mult și uneori nu identifică anumite vulnerabilități. Proiectul nostru își propune să rezolve această problemă, propunând un tool CLI asemănător Nmap, care să ruleze din terminal pe un director, să analizeze semantica integrărilor AI dintr-un proiect, semnalizând punctele slabe și sugerând rezolvări.

Descriere formală

Sistemul primește ca argument calea către un director și returnează o mulțime de vulnerabilități identificate, sub forma *F = {(fisier, linie, categorie, severitate, explicatie, fix)},* unde $categorie \in \{LLM01, \dots, LLM10\}$, iar severitate ∈{Critical, High, Medium, Low}

Importanța proiectului

Numărul de aplicații care utilizează LLM-uri este într-o continuă creștere, iar analiza manuală a vulnerabilităților este lentă și predispusă la erori. Remedierea vulnerabilităților trebuie să fie făcută cât mai repede pentru a preveni lucruri precum execuții neautorizate sau scurgeri de date.

Utilizatorii țintă

Proiectul se adresează dezvoltatorilor de LLM-uri, dar și pentru oamenii din domeniul securității cibernetice sau pentru code reviewers.

Date de intrare

Path-ul spre un repository care conține codul sursă. Analiza vizează sistemele Python (LangChain, LlamaIndex, SDK OpenAI/Anthropic) și TypeScript/Node.js (Vercel AI SDK, LangChain.js).

Date de ieșire

Rezultatele analizei sunt afișate în terminal, folosind culori pentru a face experiența utilizatorului mai plăcută. Outputul este format dintr-un Compliance Scorecard (care asociază fiecărei categorii OWASP un număr de vulnerabilități și un status pass/fail) + rezultatele propriu-zise ale analizei. Rezultatele pot fi exportate într-un fișier .json folosind opțiunea *--export*.

Măsurarea performanței

Performanța va fi măsurată comparând predicțiile rulate pe versiunea intenționat vulnerabilă a unui LLM, în raport cu versiunea securizată.